# ما يفيد مشروعنا من الدراسة

مذكرة عربية مختصرة للمراجعة والسمينار

Integrating Continuous Compliance into DevSecOps Pipelines: A Data Engineering Perspective

Aleksandr Zakharchenko · Software · 2026
الدراسة الأصلية: 24 صفحة · هذه المذكرة: صفحتان

### الفكرة التي تهمنا

تقترح الدراسة إطارًا لدمج التحقق من المتطلبات داخل خطوات التطوير، باستخدام سياسات قابلة للتنفيذ وأدلة مرتبطة بقرارات التقييم. ويتيح تصميمها تتبّع الصلة بين السياسة والبرنامج والأدلة. [1، القسمان 3 و4]

**المعنى ببساطة:** الامتثال هنا هو استيفاء شرط محدد. لكي تكون نتيجة منصتنا مفهومة، نوضح: ماذا فحصنا؟ وما الدليل؟ ومتى جمعناه؟ ولماذا حكمنا بأن الشرط مستوفٍ أو غير مستوفٍ؟

### كيف نستفيد منها في منصتنا المقترحة

ما يلي ترجمة للأفكار إلى اقتراحات تصميم لمشروعنا؛ ليس وصفًا لمنصة GitHub اختبرها الباحث.

| الفكرة | تطبيقها المقترح في مشروعنا |
|---|---|
| شرط واضح | نحوّل عبارة «المستودع آمن» إلى فحوص محددة. مثلًا: الفرع الرئيسي يشترط مراجعة واحدة على الأقل قبل الدمج، ضمن نطاق واستثناءات معلومة. |
| دليل قابل للمراجعة | نحفظ المعلومات التي اعتمد عليها الفحص، مع مصدرها ووقت جمعها والمستودع والفرع المعنيين. |
| قرار يمكن تفسيره | نربط النتيجة بالدليل ومعيار الفحص وإصداره؛ لنعرف لماذا صدرت، وكيف أثّر تغيير المعيار عليها. |
| تتبّع عبر الزمن | نحفظ كل تقييم كتسجيل مستقل. وبعد المعالجة نضيف تقييمًا جديدًا، مع إبقاء السابق للمراجعة والمقارنة. |

### حدّ الحكم الذي نصدره

إذا تحققنا من إعدادات المراجعة، نستطيع الحكم على **استيفاء شرط الإعدادات ضمن النطاق المفحوص**. أما جودة المراجعة البشرية وخلو الكود من الثغرات فهما سؤالان يحتاجان إلى أدلة أخرى.

لذلك تكون نتيجة الفحص دقيقة ومحددة، ويظهر معها النطاق والتوقيت بدل الاكتفاء بدرجة عامة يصعب تفسيرها.

# المثال وحدود الدليل العلمي

### مثال تعليمي: شرط المراجعة قبل الدمج

نفترض أن سياسة المشروع تشترط مراجعة واحدة قبل الدمج في الفرع الرئيسي. تقرأ منصتنا الإعدادات المتاحة عبر API بصلاحيات مناسبة، وتقارنها بمعيار الفحص المحدد.

| ما تحققنا منه | النتيجة التي نسجلها |
|---|---|
| الشرط مفروض | مستوفٍ لهذا الشرط، مع الدليل والنطاق والتوقيت. |
| الشرط غير مفروض | غير مستوفٍ، وتُنشأ مهمة معالجة إذا كان ذلك ضمن متطلبات المنصة. |
| تعذرت قراءة الإعدادات | تعذّر التحقق، مع السبب؛ لا نفترض الاستيفاء أو عدمه. |

إذا تغيّرت الإعدادات اليوم، لا نستبدل نتيجة الأمس؛ نضيف تقييم اليوم ونحدّث الحالة المعروضة. وإذا تعذّر الفحص، نظهر آخر نتيجة بتوقيتها بوصفها نتيجة سابقة.

### ماذا اختبر الباحث فعليًا؟

اختبر نموذجًا محليًا باستخدام Docker، بتنفيذ المراحل بالتتابع وعشر تشغيلات متتالية بالإعدادات نفسها. شمل المسار بناء صورة حاوية، وإنتاج قائمة مكوناتها (SBOM) وفحص الثغرات، وتقييم سياسة بأداة OPA، وحفظ الأدلة وتوقيع نتائج الامتثال رقميًا، مع قياس أزمنة المراحل. [1، القسم 6]

تظل آليات الفرض أثناء التشغيل والمعالجة الذاتية مقترحات معمارية غير مثبتة تجريبيًا في الورقة. [1، القسم 7.4]

**قراءتنا لهذه النتائج:** تدعم إمكانية تنفيذ مسار محدود يربط الفحص بقرار وأدلة. لكنها لا تكفي لإثبات توفير جهد فريق حقيقي، أو نجاح منصة تقييم مستودعات كاملة.

### ما نأخذه وما نحتاج إلى إثباته

نأخذ وضوح الفحص وربط القرار بالدليل والتاريخ، ونختار تخزينًا يناسب حجم مشروعنا. اختيار أدوات الدراسة أو بنية تخزينها يحتاج إلى حاجة فعلية في متطلباتنا.

لتقييم منصتنا، نتحقق من صحة النتائج على حالات معلومة، ومن كفاية الأدلة لتفسيرها، ونقارن الوقت والجهد لمهام متكافئة مع المنصة وبدونها. وجود هذه الوظائف وحده لا يثبت تميزنا؛ نحتاج إلى مقارنة واضحة وفائدة قابلة للقياس.

**المصدر:** [1] نص الدراسة لدى الناشر · DOI: 10.3390/software5010006
للقراءة الانتقائية: الأقسام 3 و4 للأفكار، و6 للتجربة، و7.4 للقيود.